

# DÉPLOIEMENT D'UN MINI-SOC AVEC WAZUH

SURVEILLANCE, DÉTECTION  
D'INTRUSIONS ET RÉPONSE ACTIVE  
MULTI-OS

2026

## DOCUMENT RÉALISÉ PAR :

Lauryn HECQUE--NASCIMENTO  
Mehdi BEN MOULAY

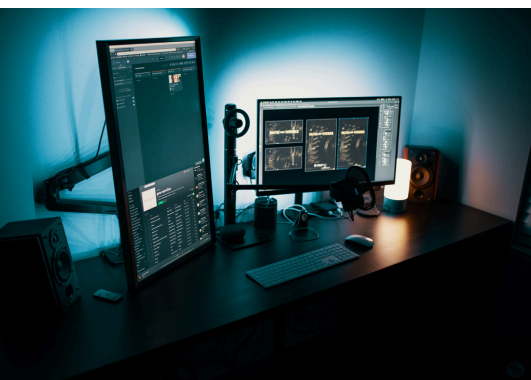
SEPTEMBRE 2026

# SOMMAIRE



|                                                                         |                |
|-------------------------------------------------------------------------|----------------|
| Contexte & Expression du Besoin                                         | <b>03</b>      |
| Architecture Technique & Choix Technologiques                           | <b>04 - 05</b> |
| Mise en Œuvre de l'Infrastructure                                       | <b>06 - 07</b> |
| Ingénierie de Détection & Simulation d'Attaques (MITRE ATT&CK)          | <b>08 - 09</b> |
| Réponse Active & Remédiation Automatique                                | <b>10</b>      |
| Intégration Threat Intelligence (OSINT / VirusTotal) & Alerting Discord | <b>11</b>      |
| Fiche de Traitement d'Incident SOC                                      | <b>12</b>      |
| Matrice des Compétences SISR Mobilisées                                 | <b>13</b>      |
| Bilan, Limites et Perspectives d'Évolution                              | <b>14</b>      |

# CONTEXTE & EXPRESSION DU BESOIN



## CONTEXTE PROFESSIONNEL

Dans le cadre de la sécurisation d'une PME de 40 collaborateurs exploitant un parc informatique hétérogène (postes de travail Windows et serveurs applicatifs Linux), la direction a constaté une absence totale de visibilité sur les événements de sécurité internes. L'organisation est confrontée à une recrudescence de menaces : tentatives d'usurpation d'identifiants, exécution de scripts malveillants et attaques par force brute sur les accès distants.



## PROBLÉMATIQUE

Comment centraliser, corrélérer et analyser les journaux d'événements multi-OS en temps réel afin de détecter des comportements anormaux, alerter les équipes et automatiser la neutralisation des menaces sans alourdir les coûts d'infrastructure ?

## OBJECTIFS DU PROJET

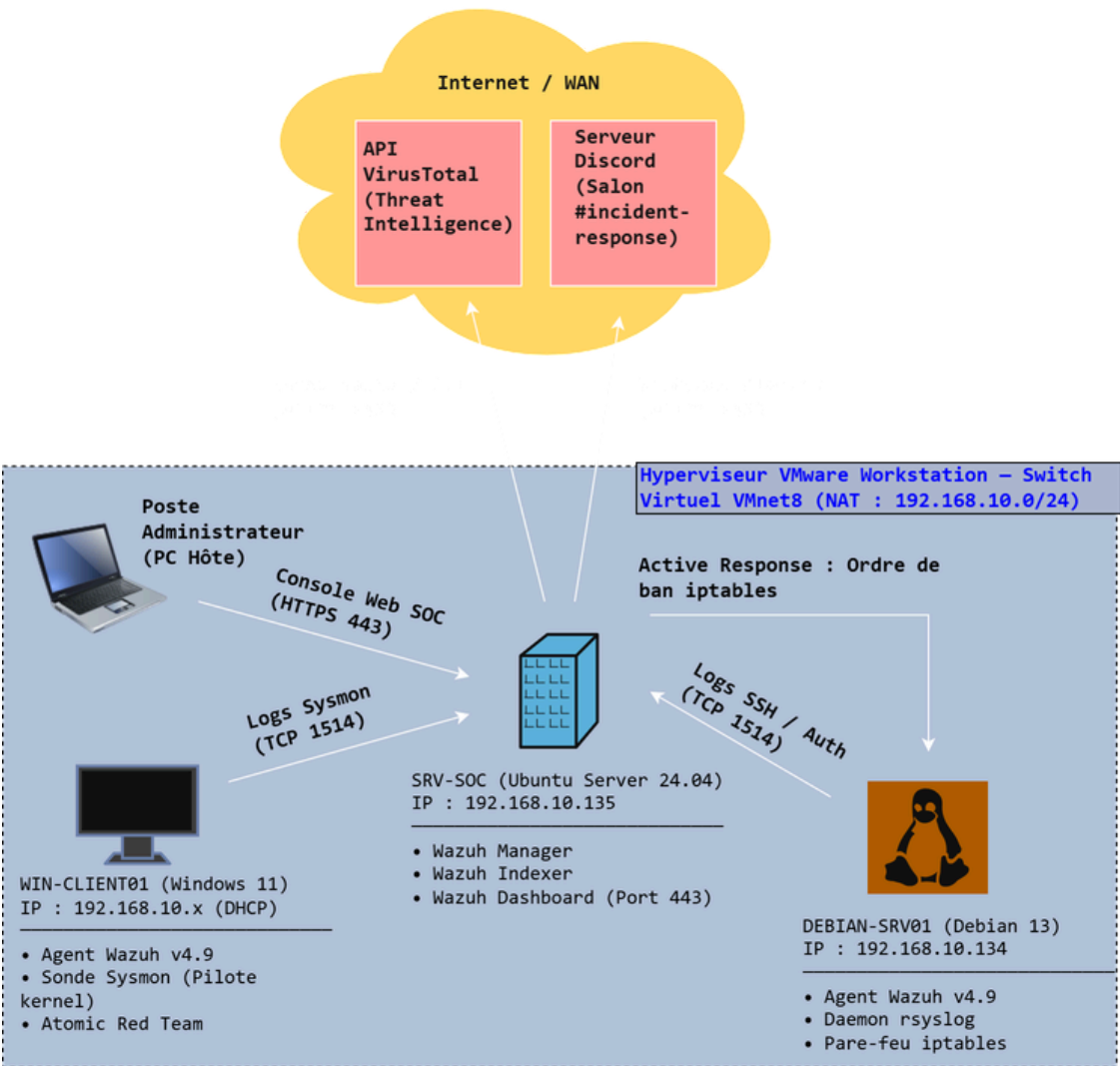
- Déployer une solution de centralisation et corrélation de journaux (SIEM / XDR open-source).
- Améliorer la télémétrie Windows grâce au déploiement d'une sonde bas-niveau (Sysmon).
- Simuler des attaques réalistes alignées sur le standard industriel MITRE ATT&CK.
- Créer des règles de détection sur-mesure (Detection Engineering).
- Mettre en place un mécanisme de remédiation automatisée (Active Response).
- Connecter le système à une source de renseignement sur les menaces (VirusTotal CTI) et à un système de notification d'astreinte en temps réel (Discord Webhook).

# ARCHITECTURE TECHNIQUE & CHOIX TECHNOLOGIQUES

## SPÉCIFICATIONS MATÉRIELLES ET ADRESSAGE RÉSEAU

L'ensemble de l'infrastructure est virtualisé sur un hyperviseur de type 2 (VMware Workstation) au sein d'un réseau privé virtuel en mode NAT (192.168.10.0/24) garantissant un cloisonnement strict avec l'environnement physique.

| Machine      | Rôle / OS                     | CPU / RAM     | Adresse IP          | Services / Rôles                                   |
|--------------|-------------------------------|---------------|---------------------|----------------------------------------------------|
| SRV-SOC      | Serveur Wazuh (Ubuntu Server) | 4 vCPU / 8 Go | 192.168.10.135      | Manager, Indexer, Dashboard, API (1514, 1515, 443) |
| WIN-CLIENT01 | Endpoint Cible (Windows 11)   | 2 vCPU / 4 Go | DHCP (192.168.10.x) | Agent Wazuh, Sysmon, Atomic Red Team               |
| DEBIAN-SRV01 | Serveur Cible (Debian 13)     | 1 vCPU / 2 Go | 192.168.10.134      | Agent Wazuh, SSH (22), iptables, rsyslog           |



# ARCHITECTURE TECHNIQUE & CHOIX TECHNOLOGIQUES

## JUSTIFICATION DES CHOIX TECHNOLOGIQUES

- Wazuh plutôt qu'un SIEM propriétaire (Splunk, Sentinel) : Solution open source mature, sans coût de licence volumétrique, combinant les fonctionnalités d'un SIEM (corrélation de logs) et d'un XDR/HIDS (contrôle d'intégrité, réponse active).
- Sysmon (System Monitor) : Les journaux Windows de sécurité par défaut manquent de granularité (notamment sur l'imbrication des processus et les injections mémoire). Sysmon comble cette lacune en traçant la création des processus avec les arguments de ligne de commande complets (Event ID 1) et l'accès à la mémoire LSASS (Event ID 10).
- Framework MITRE ATT&CK : Référentiel mondial permettant d'évaluer la couverture de détection en fonction des tactiques et techniques réelles des cyberattaquants.

# MISE EN ŒUVRE DE L'INFRASTRUCTURE

## DÉPLOIEMENT DU SERVEUR WAZUH (ALL-IN-ONE)

- Provisionnement d'une VM Ubuntu Server configurée avec 4 vCPU et 8 Go de RAM.
- Extension à chaud du volume logique racine via LVM (lvextend -l +100%FREE et resize2fs) pour garantir un espace disque supérieur au prérequis de 10 Go.
- Installation assistée de la suite Wazuh (Manager, Indexer, Dashboard).
- Validation de l'accessibilité de l'interface d'administration en HTTPS (<https://192.168.10.135>).

## TÉLÉMÉTRIE WINDOWS (SYSMON & AGENT WAZUH)

- Déploiement du pilote et service Sysmon64 avec le modèle de filtrage recommandé par l'industrie (SwiftOnSecurity config).
- Installation et enregistrement de l'agent Wazuh Windows.
- Modification du fichier de configuration de l'agent (ossec.conf) pour ingérer le canal d'événements :

**<localfile>**

**<location>Microsoft-Windows-Sysmon/Operational</location>**

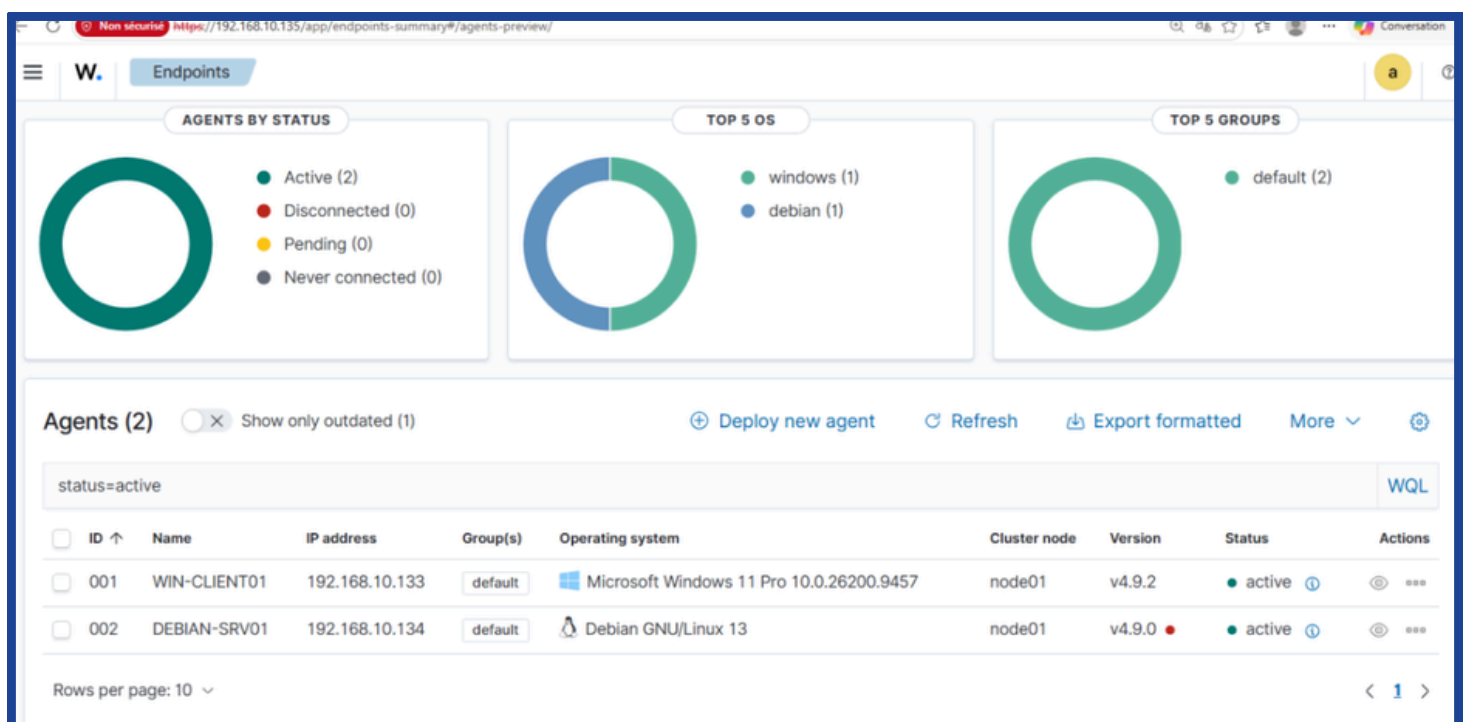
**<log\_format>eventchannel</log\_format>**

**</localfile>**

## ENDPOINT LINUX (DEBIAN 13)

- Déploiement de l'agent via le paquet binaire .deb officiel.
- Résolution du comportement natif de Debian 12/13 par l'installation des paquets rsyslog (génération physique du fichier /var/log/auth.log) et iptables (support des scripts de filtrage réseau).
- Raccordement validé au serveur central sur le port TCP 1514.

Cette vue de la console d'administration atteste du bon enrôlement et de la communication bilatérale en temps réel entre le gestionnaire Wazuh (SRV-SOC) et les deux cibles du parc. Les agents WIN-CLIENT01 (Windows 11) et DEBIAN-SRV01 (Debian 13) présentent tous deux le statut Active (indicateur vert), validant l'ouverture des flux sur le port TCP 1514, l'envoi régulier des battements de cœur (keepalives) et la transmission effective de la télémétrie système vers le SIEM.



# INGÉNIERIE DE DÉTECTION & SIMULATION D'ATTAQUES

## TEST PRÉLIMINAIRE : DÉCOUVERTE DE COMPTES (T1087.001)

- Action : Exécution du module Atomic Red Team Invoke-AtomicTest T1087.001 sur Windows (énumération locale des comptes utilisateurs).
- Résultat : Ingestion immédiate des événements dans Wazuh et affichage dans la matrice MITRE ATT&CK (Tactique : Discovery).

## ATTAQUE AVANCÉE : PERSISTANCE PAR CLÉ DE REGISTRE RUN (T1547.001)

- Technique adverse : L'attaquant insère une valeur exécutable sous HKCU\Software\Microsoft\Windows\CurrentVersion\Run pour maintenir son accès au redémarrage de la machine.
- Constat initial : L'événement est intercepté par Sysmon (Event ID 13 - RegistryEvent Value Set), mais il est classé à un niveau de sévérité faible par défaut (niveau informatif).
- Développement d'une règle de détection sur-mesure :
- Ajout d'une règle personnalisée dans /var/ossec/etc/rules/local\_rules.xml sur le Manager :

**<!-- Règle de détection SOC personnalisée : Persistance Run -->**

**<rule id="100005" level="12">**

**<if\_sid>61613, 61614, 61615</if\_sid>**

**<field name="win.eventdata.targetObject" type="pcre2">(?**

**i)CurrentVersion.\*Run</field>**

**<description>ALERTE SOC : Tentative de persistance detectee dans la cle de registre Run</description>**

**<mitre>**

**<id>T1547.001</id>**

**</mitre>**

**</rule>**

- Validation : Après rechargement de la configuration (wazuh-manager), une nouvelle exécution de l'attaque déclenche immédiatement l'alerte 100005 en Niveau 12 (Critique).

| Export Formated 622 columns hidden Density 1 fields sorted Full screen |                             |              |                                    |            |         |
|------------------------------------------------------------------------|-----------------------------|--------------|------------------------------------|------------|---------|
|                                                                        | timestamp                   | agent.name   | rule.description                   | rule.level | rule.id |
|                                                                        | Sep 23, 2026 @ 16:19:10.997 | WIN-CLIENT01 | ALERTE SOC : Tentative de persi... | 12         | 100005  |
|                                                                        | Sep 23, 2026 @ 16:18:08.233 | WIN-CLIENT01 | ALERTE SOC : Tentative de persi... | 12         | 100005  |

# RÉPONSE ACTIVE & REMÉDIATION AUTOMATIQUE

Pour éviter une posture purement passive, un mécanisme d'auto-défense (SOAR-lite) a été déployé pour protéger l'accès distant du serveur Linux.

Configuration du module Active Response (ossec.conf sur Ubuntu) :

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5710, 5712, 5716, 5720</rules_id>
  <timeout>60</timeout>
</active-response>
```

Simulation d'attaque par Brute-Force SSH :

Tentatives consécutives d'authentification SSH infructueuses avec un utilisateur inexistant (pirate).

**Résultat :** Dès la 4<sup>e</sup> tentative infructueuse, le gestionnaire ordonne à la machine Debian de bloquer la source de l'attaque. L'adresse IP attaquante est automatiquement insérée dans la table de filtrage iptables en action DROP pour une durée de 60 secondes.

```
root@debian02: # iptables -L -n -v
Chain INPUT (policy ACCEPT 299 packets, 39584 bytes)
 pkts bytes target    prot opt in     out     source    destination
   8  1088 DROP      all  --  *      *        192.168.10.1  0.0.0.0/0

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source    destination
   0     0 DROP      all  --  *      *        192.168.10.1  0.0.0.0/0

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source    destination
```

# INTÉGRATION THREAT INTELLIGENCE (VIRUSTOTAL) & ALERTING DISCORD

## SURVEILLANCE D'INTÉGRITÉ (FIM) & CTI VIRUSTOTAL

- Activation du contrôle d'intégrité des fichiers (FIM / syscheck) en temps réel sur le répertoire Windows C:\TestMalware.
- Interconnexion de Wazuh avec l'API publique de VirusTotal pour corrélérer automatiquement le hash des nouveaux exécutables.
- Test avec le binaire international inoffensif EICAR : le gestionnaire extrait le hash SHA256, interroge VirusTotal, et déclenche la règle critique 87105 (VirusTotal: Alert - File is a virus) affichant le taux de positivité des moteurs antivirus mondiaux.

## AUTOMATISATION DES ALERTES D'ASTREINTE VIA DISCORD WEBHOOK

- Pour assurer une chaîne d'astreinte opérationnelle :
- Développement d'un script d'intégration Python (/var/ossec/integrations/custom-discord) traitant les données JSON d'alertes générées par le moteur d'analyse.
- Déclaration dans ossec.conf avec un filtre de déclenchement fixé au Niveau 12 ou supérieur.
- Lors du déclenchement de la règle 100005, une notification visuelle (*Rich Embed*) contenant la machine cible, la règle violée et la technique MITRE est envoyée en direct dans le canal d'astreinte # 🚨-incident-response.

**BlueScope SOC Sentinel** APP 16:46

 **[ALERTE SOC - NIVEAU 12]**

Sysmon - Suspicious Process - taskhost.exe

| Machine Cible                 | ID Règle | Technique MITRE |
|-------------------------------|----------|-----------------|
| WIN-CLIENT01 (192.168.10.133) | 61634    | T1055           |

BlueScope Technologies • Detection & Incident Response

# FICHE DE TRAITEMENT D'INCIDENT SOC

| Champ                 | Informations du Ticket d'Incident                                                                                                                    |
|-----------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| Identifiant Incident  | INC-2026-0042-PERSIST                                                                                                                                |
| Date & Heure          | 20/09/2026 à 21:54:48 UTC                                                                                                                            |
| Niveau de Criticité   | <b>CRITIQUE (Niveau 12)</b>                                                                                                                          |
| Machine Impactée      | WIN-CLIENT01 (VLAN/Sous-réseau 192.168.10.0/24)                                                                                                      |
| Classification MITRE  | Tactique : Persistence / Technique : T1547.001 (Registry Run Keys)                                                                                   |
| Vecteur de Détection  | Sonde Sysmon (Event ID 13)<br>→ Règle locale Wazuh 100005                                                                                            |
| Canal de Notification | Webhook d'urgence Discord SOC                                                                                                                        |
| Analyse & Confinement | Identification de la clé créée sous HKCU\...\CurrentVersion\Run. Fichier exécutable associé analysé via FIM / Threat Intelligence.                   |
| Remédiation appliquée | 1. Suppression manuelle/automatisée de la clé malveillante.<br>2. Verrouillage des droits d'écriture sur les clés Run par stratégie de groupe (GPO). |

# MATRICE DES COMPÉTENCES BTS SIO SISR MOBILISÉES

| Bloc de compétences                                  | Sous-compétence officielle                                     | Application concrète dans le projet                                               |
|------------------------------------------------------|----------------------------------------------------------------|-----------------------------------------------------------------------------------|
| <b>B1 – Gérer le patrimoine informatique</b>         | Recenser et identifier les ressources du SI                    | Déploiement et enregistrement d'agents sur Windows 11 et Debian 13.               |
| <b>B1 – Gérer le patrimoine informatique</b>         | Mettre en place et vérifier les niveaux d'habilitation         | Sécurisation des accès root/sudo et gestion des permissions du démon Wazuh.       |
| <b>B2 – Répondre aux incidents</b>                   | Collecter, suivre et orienter des demandes                     | Centralisation et analyse des journaux d'événements multi-OS dans le SIEM.        |
| <b>B2 – Répondre aux incidents</b>                   | Traiter des incidents et des demandes d'assistance             | Mise en place de règles de détection sur-mesure et remédiation active.            |
| <b>B3 – Sécuriser les équipements et les données</b> | Protéger les données à caractère personnel et l'infrastructure | Filtrage pare-feu dynamique (iptables), intégration d'API de renseignement (CTI). |
| <b>Développement / Automatisation</b>                | Conception d'outils d'administration et d'intégration          | Écriture du script Python d'envoi Webhook et manipulation de fichiers             |

# BILAN, LIMITES ET PERSPECTIVES D'ÉVOLUTION

## BILAN TECHNIQUE

L'ensemble des objectifs initiaux a été atteint : l'infrastructure permet la centralisation des logs d'un parc mixte, la détection précise d'activités malveillantes via Sysmon, la réaction automatique face aux intrusions réseaux et l'alerte immédiate des équipes de sécurité.

## LIMITES IDENTIFIÉES

- Point de défaillance unique (SPOF) : L'architecture actuelle repose sur une instance Wazuh unique. En environnement de production étendu, une indisponibilité du serveur entraîne une perte temporaire de surveillance.
- Quotas API CTI : L'usage de l'API publique gratuite de VirusTotal limite l'analyse à 4 requêtes/minute, ce qui engendre des erreurs (règle 87101) en cas de vagues de fichiers simultanés.

## PERSPECTIVES D'ÉVOLUTION

- Haute Disponibilité : Migration vers un cluster multi-nœuds (2 Wazuh Indexers + 2 Managers en load-balancing).
- Automatisation étendue (SOAR) : Développement d'un script de confinement Windows pour isoler logiquement l'hôte du réseau via l'API locale dès détection d'un ransomware.
- Volet Externe (OSINT) : Intégration du script de reconnaissance de surface d'attaque (bluescope\_recon.py) pour alimenter les alertes du SIEM avec les vulnérabilités de périmètre découvertes en amont.